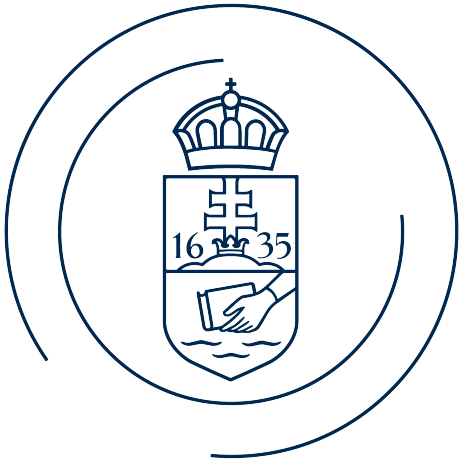


ELTE
EÖTVÖS LORÁND
UNIVERSITY

10101101001010101011101011010010101010111011101011010010101010100

Cybersecurity basics

The Essentials of Password Security

Password Security

What you will learn...



- What exactly are passwords?
- What makes a password strong?
- What methods are used to store passwords in databases?
- Why should passwords be complex to enhance security?
- What are hash functions, and why are they used?
- Why should passwords never be stored in plain text?
- How long does it take to crack passwords (GPU vs CPU)?
- How do attackers attempt to crack passwords?

Password Security

What is the concept of passwords?



Passwords are the most common **form of authentication** used to log in to systems, applications, and websites. They serve as a **unique identifier**, allowing users to **prove their identity** and gain access to protected resources. A strong password acts as a digital key, safeguarding sensitive information from unauthorized access. However, their effectiveness heavily depends on how they are created, managed, and protected, **as weak or compromised passwords remain a primary target for cyberattacks**.

Definitions

Definition: Username

A username is a **unique identifier** that represents an individual, account, or entity within a system, application, or network. It is used to **distinguish one user from another**.

Definition: Password

A password is a **secret combination** of characters, such as letters, numbers, and symbols, used to verify a user's identity. It acts as a security mechanism to ensure that only authorized individuals can access an account or system.

The username identifies **who the user is**, while the **password verifies that the user is who they claim to be**. In essence, the username is **public information**, and the password is **private and should be kept secure**.

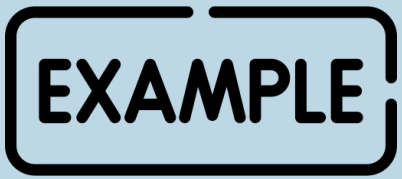
Password complexity

Password complexity

Creating a secure password involves constructing a **unique and complex combination** of characters that is difficult for others to guess or crack. A secure password should include a mix of uppercase and lowercase letters, numbers, and special characters, and it should avoid predictable patterns, dictionary words, or personal information. Ideally, the password **should be at least 12-16 characters long, unique for each account**, and stored securely in a trusted password manager to minimize reuse and potential breaches.

Password Security

Examples of weak and strong passwords

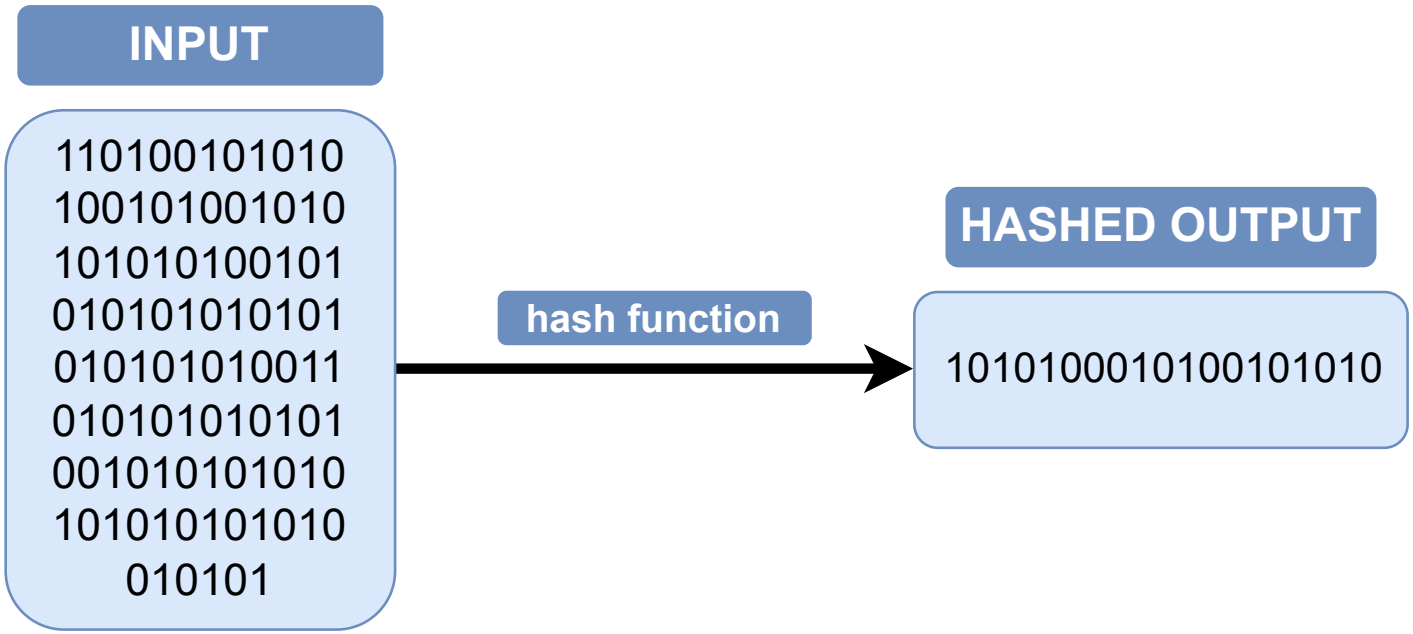


Password	Complexity
123456	Weak
Qwertyuiop	Weak
Password1!	Weak
!@#$%&*	Weak
Hkdj371	Medium
BlueSky#2023	Medium
Tiger@Rock1	Medium
RainyDay#4	Medium
MlkX_GHL!0d1	Hard
This_P@55w0rdZ4R3H@rd2_Gue$$	Hard
ThisPasswordknown!OnlyByMe!	Hard

If passwords are **stored in plaintext** within a database, the complexity of the passwords **becomes irrelevant**. A malicious attacker can easily view the passwords and reuse them without any additional effort. To address this, we use the so-called **hash functions**.

Definition: hash function

A **hash function** is a computationally efficient function mapping binary strings of arbitrary length to binary strings of some fixed length, called *hash-values*. $\mathbf{H} : \{0,1\}^* \rightarrow \{0,1\}^k$



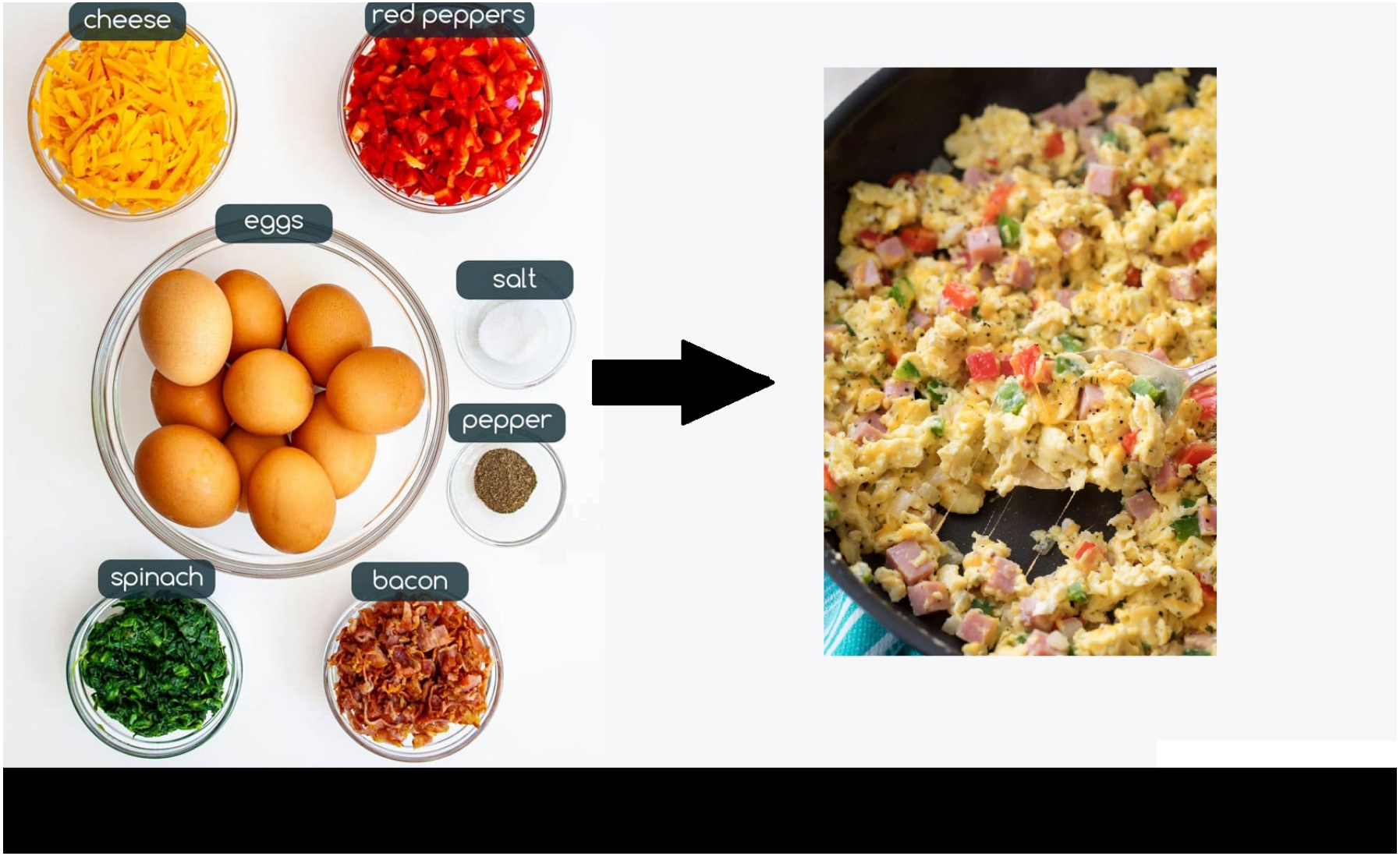
What is Cryptographic hash function?

Definition: Cryptographic Hash Function

A cryptographic hash function is a mathematical algorithm that maps data of arbitrary size to a bit string of a fixed size (a hash function) which is designed to also be **one-way function**, that is, a function which is **infeasible to invert**.

The input data is often called the **message**, and the output (the hash value or hash) is often called the **message digest** or simply the digest.

One-way : infeasible to invert



Properties of cryptographic hash functions

The ideal cryptographic hash function has four main properties:

Properties of cryptographic hash functions

- It is quick to compute the hash value for any given message;
- It is infeasible to generate a message from its hash value except by trying all possible messages;
- A small change to a message should change the hash value so extensively that the new hash value appears uncorrelated with the old hash value;
- It is infeasible to find two different messages with the same hash value.

Avalanche effect

Avalanche effect

An important and desirable feature of a good hash function is the non-correlation of input and output, or so-called **avalanche effect**, which means that a small change in the input results in a significant change in the output, making it statistically indistinguishable from random.

Example:

- MD5(**123456**) $->$ `e10adc3949ba59abbe56e057f20f883e`
- MD5(**1234567**) $->$ `fcea920f7412b5da7be0cf42b8c93759`

Cryptanalysis attacks

A cryptographic hash function must be able to withstand all known types of cryptanalytic attack:

- **Pre-image resistance:** Given a hash value h. It should be difficult to find any message m such that $h = H(m)$.
- **Second pre-image resistance:** Given an input m_1. It should be difficult to find different input m_2 such that $H(m_1) = H(m_2)$.
- **Collision resistance:** It should be difficult to find two different messages m_1 and m_2 such that $H(m_1) = H(m_2)$. Such a pair is called a cryptographic hash collision.

Birthday Paradox

What's the probability that two people on the football/soccer pitch share a birthday? (day and month)

Birthday Paradox

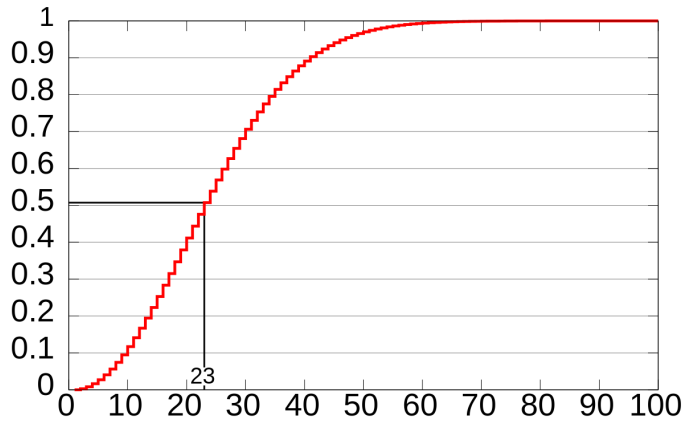
In probability theory, the birthday paradox concerns the probability that, in a set of n randomly chosen people, some pair of them will have the same birthday.

The probability reaches 100% when the number of people reaches 367 (including February 29)

99.9% probability is reached with just 70 people, and 50% probability with 23 people.

Birthday Attack

$$P(A) = 1 - \frac{366!}{366^N (366 - N)!}$$



A birthday attack is a type of cryptographic attack that exploits the mathematics behind the birthday problem.

Birthday Attack

A collision in a H function can be found with probability 1/2 by computing $2^{n/2}$ hash value.

MD5 Cryptanalysis Overview

MD5 is a widely used cryptographic hash function producing a 128-bit hash value, designed by Ronald Rivest in 1991. Over time, several vulnerabilities have been discovered:

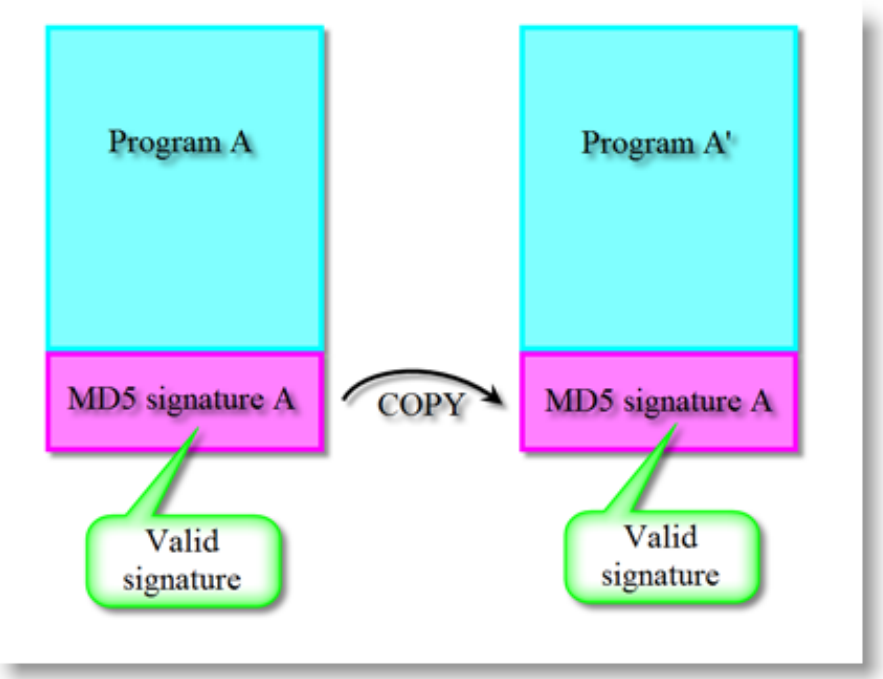
MD5 Cryptanalysis Overview - PART I

- **1993:** Pseudo-collision in the compression function by B. den Boer and A. Bosselaers.
- **1996:** Semi-free start collision by H. Dobbertin.
- **2004:** MD5CRK birthday attack launched by Jean-Luc Cooke. Analytical hash collision attack within 1 hour by Xiaoyun Wang et al.
- **2005:** Wang and Yu published an algorithm to find two 128-byte sequences with the same MD5 hash.
- **2007:** Chosen prefix collision method by Marc Stevens et al. Example:
  - hello.exe MD5: cdc47d670159eef60916ca03a9d4a007
  - erase.exe MD5: cdc47d670159eef60916ca03a9d4a007

MD5 Cryptanalysis Overview

MD5 Cryptanalysis Overview - PART II

- **2007:** Fast Collision Finding program based on Marc Stevens' thesis.
- **2009:** Didier Stevens used the evilize program to create two programs with the same Authenticode digital signature.

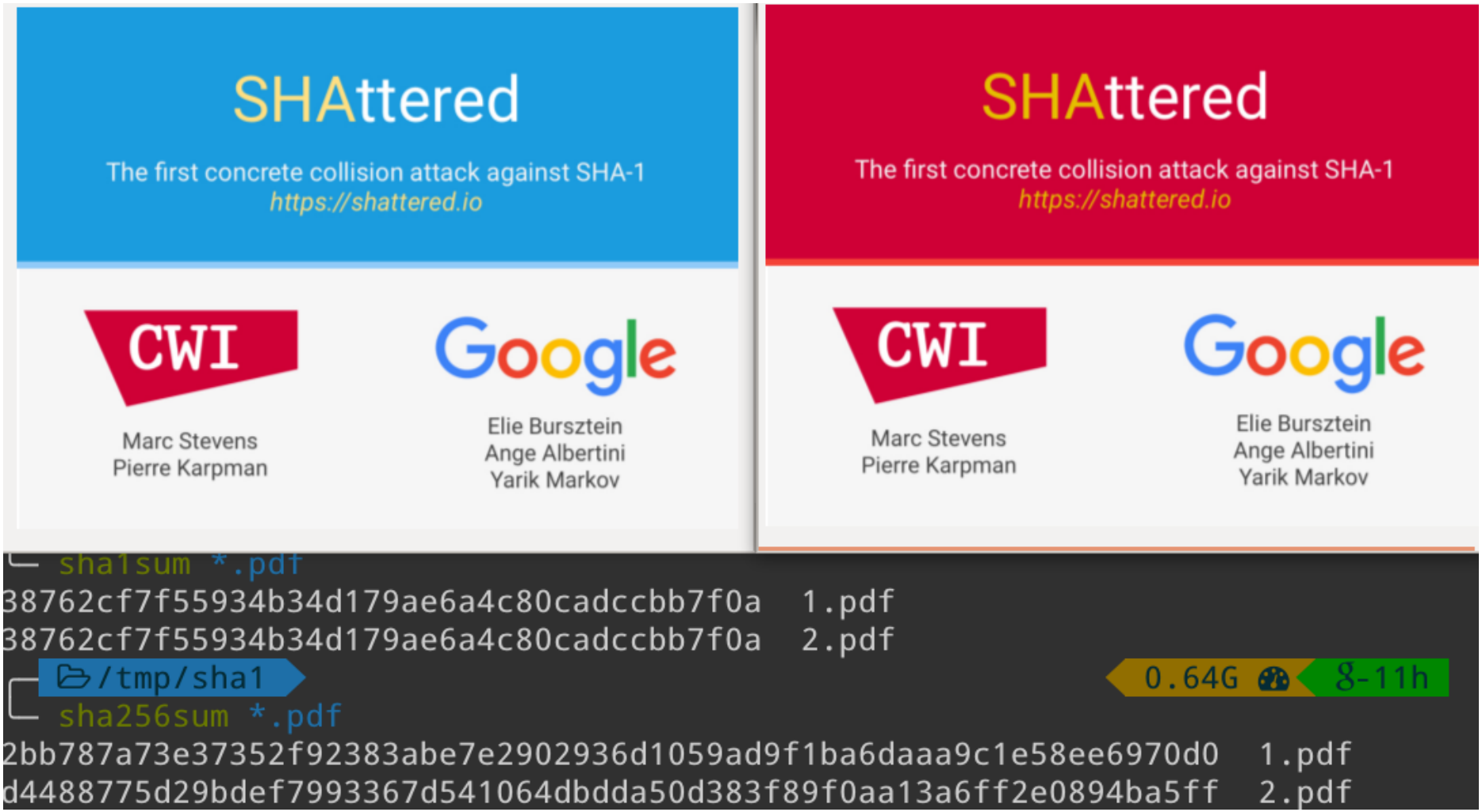


MD5 Cryptanalysis Overview

MD5 Cryptanalysis Overview - PART III

- **2010:** Tao Xie and Dengguo Feng constructed the first single-block collision for MD5.
- **2012:** Single-block collision attack (Marc Stevens).
- **2013:** Xie Tao, Fanbao Liu, and Dengguo Feng demonstrated a 2-block collision in less than a second on a regular computer.

First collision for SHA1 by Google - 2017



Facts about hash functions

- MD5, SHA1 is considered cryptographically **NOT** secure hash functions
- SHA2, SHA3 (Keccak) is cryptographically secure hash functions
- For password hashing PBKDF2 (Password Based Key Derivation Function), Bcrypt or Scrypt **should be** used.
- In 2013 a long-term Password Hashing Competition was announced to choose a new, standard algorithm for password hashing. On 20 July 2015 **Argon2** was selected as the final PHC winner.

Advanced password cracking techniques

Massive data breaches - I.

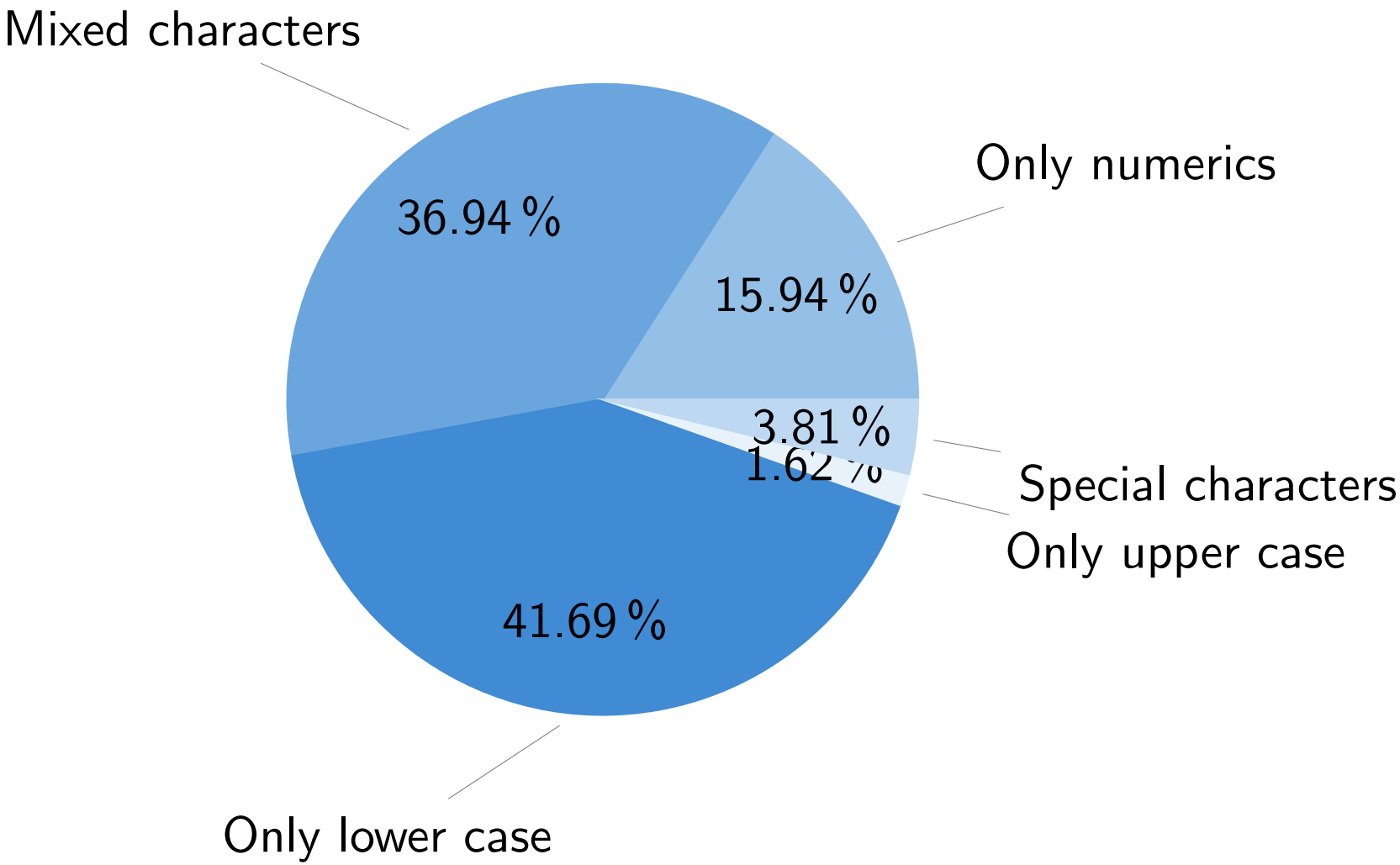
- **Yahoo:** Yahoo announced in September 2016 that in 2013-2014 it had been the victim of what would be **the biggest data breach in history**. Yahoo reported that approximately **3 billion** user accounts were compromised.
- **Mariott:** In 2018 November Marriott International announced that attackers had stolen data on approximately **500 million** customers.
- **Adult Friend Finder:** In October 2016 approximately **412.2 million** accounts compromised.
- **Zynga:** In Septemper 2019 approximately **218 million** Zynga email addresses, salted SHA-1 hashed passwords, phone numbers, and user IDs for Facebook and Zynga accounts were stolen.

Massive data breaches - II.

1. **Dubsmash:** In December 2018, New York-based video messaging service Dubsmash had **162 million** email addresses, usernames, PBKDF2 password hashes were compromised.
2. **Linkedin:** Originally compromised in 2012, it was revealed in 2016 that the data of over **150 million** users was affected. Passwords were stored as SHA1 with no salting.
3. **Adobe:** In October 2013 over **150 million** username and hashed password pairs taken from Adobe.
4. **Ebay:** In 2014 march, 145 million eBay accounts were compromised in massive hack including email addresses and encrypted passwords.

Analyzing cleartext passwords

Sometimes cleartext passwords are also compromised. Analysis of 32 million cleartext password leaked from RockYou:



Letter frequency distribution

Database	The first 10 most common letters
Google	$a, e, 1, i, n, r, o, s, 2, l$
Yahoo	$a, e, i, o, 1, r, n, s, l, t$
RockYou	$a, e, 1, i, o, n, r, l, s, 0$

Table: Letter frequencies in various databases.

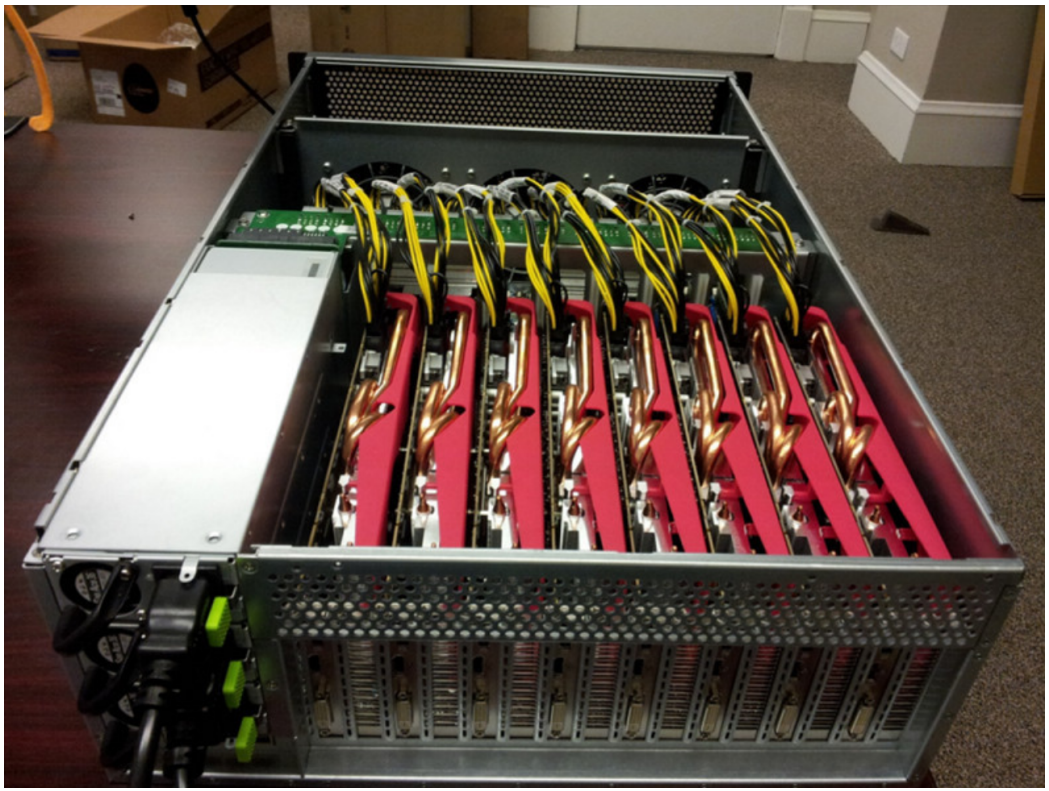
A sophisticated tool for Password cracking: hashcat

Hashcat: World's fastest and most advanced GPGPU-based password recovery utility.

- Free and Open-source
- Multi-Hash (up to 100 million hashes)
- Multi-GPU (up to 128 gpus)
- Linux,Windows
- **Rule-based** engine (Very fast Rule-engine)
- Able to work in an distributed environment
- **More than 300+ algorithms implemented**

Dedicated 25 GPU Setup - 2012

Five 4U servers equipped with 25 AMD Radeon-powered GPUs linked together using an Infiniband switched fabric link can crunch through up to 348 billion password hashes per second. **Complex Windows password can be cracked within a few hours.**



GPU Cracking in 2025 - RTX 4090



- GeForce RTX 4090 24GB RAM
- Current price: $\approx$ 2700 USD
- up to 16384 CUDA cores
- **288.5 billion NTLM passwords /sec**
- To achieve $\approx$ 0.5 trillion password /sec you need only 2 RTX 4090 GPU cards.
- To crack an 8-character-long random password containing uppercase letters, lowercase letters, and numbers, it would take approximately $62^8/60/(288.5 * 10^9) \approx$ **12 minutes**.

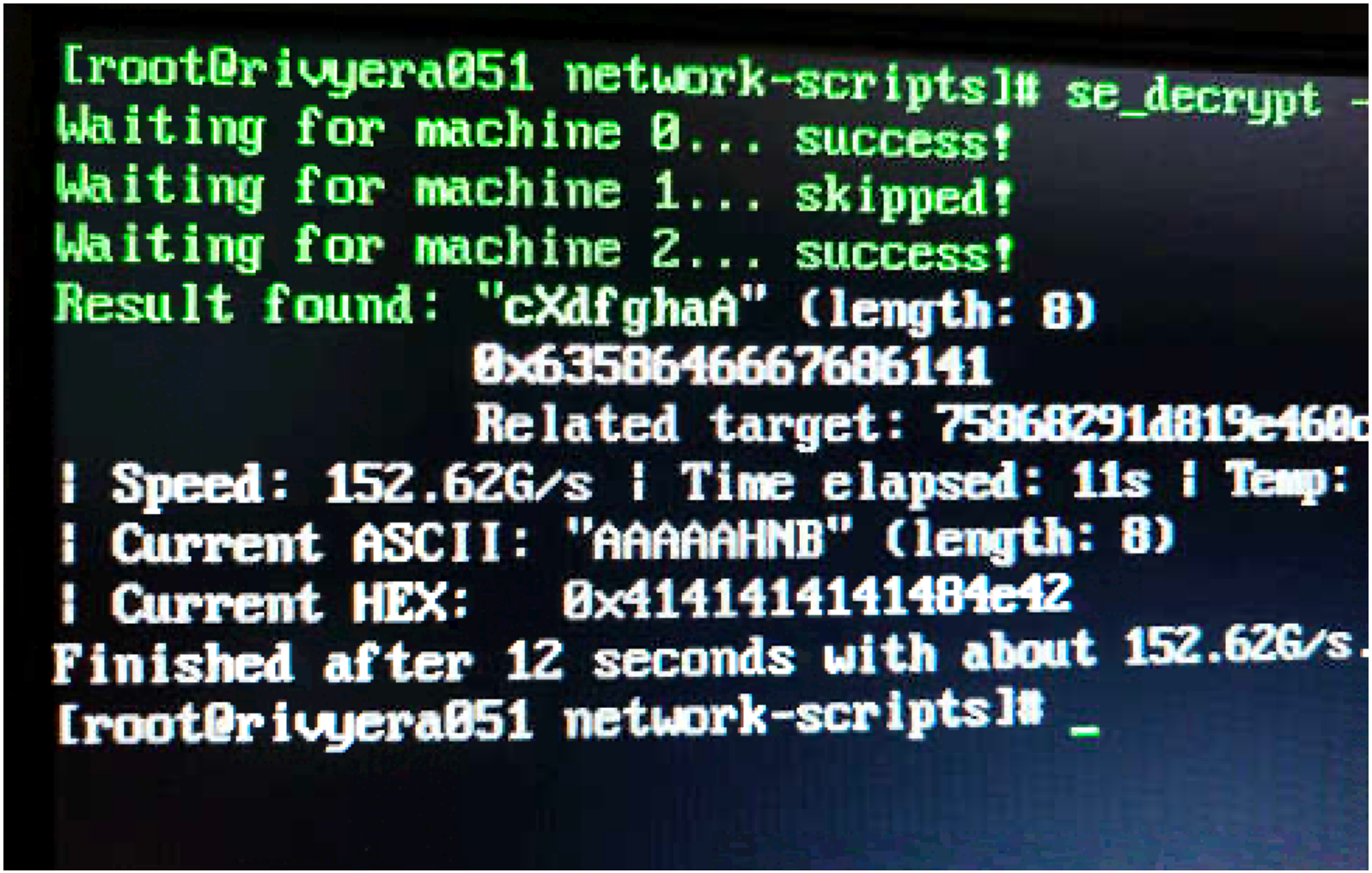
RIVYERA FPGA cracking cluster





- 2x 4U chassis RIVYERA S6-LX150 cracking server
- Ecah server contains 128x Xilinx Spartan-6 LX150 (XC6SLX150) FPGAs
- up to 30000 CPU cores performance per machine
- Green super-computing at 1280 Watt per machine

MD5 cracking example



MD5 example: Random password contains uppercase and lowercase letters cracked in 11 sec. The password is: **cXdfghaA**.